16 Using verifiable credentials for authorization

This chapter covers

- Why traditional account-based and federated identity models face challenges when authority exists outside the organization
- How verifiable credentials enable portable, cryptographically verifiable claims for authorization decisions
- How organizations can build trust and confidence in credential-based attributes
- How credential presentations are used in policy evaluation
- Patterns for integrating verifiable credentials with policy-based authorization models, including attribute- and relationship-based methods.

As ACME's collaboration platforms expanded—including the legacy Customer Collaboration system and the newer multi-tenant Customer Collaboration Cloud (C^3)—they came to support several closely related service areas: the traditional customer and project work, a portal that manufacturers use for managing suppliers, a clinic-integration API and management system branded ACME Health, and a platform that ACME provides to other companies for supporting their service technicians in the field. These are not standalone products so much as different expressions of the same platform. Each one depends on authorization decisions that must be made quickly and consistently with high assurance, even when the people involved have no accounts in ACME's internal identity systems.

For internal employees, ACME's identity system works well. Accounts are provisioned in the corporate directory, roles and attributes flow into the authorization layer, and lifecycle events are tied to HR systems. The issues occur when ACME needs to give access to non-employees. Contractors, independent auditors, partner-clinic staff, supplier representatives, and field